

Clase 171 — Active Directory: Kerberoasting y ataques a Kerberos

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *The Hacker Recipes (Kerberos) / MITRE ATT&CK T1558*  Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Entender el protocolo Kerberos lo suficiente para atacar sus puntos débiles: Kerberoasting (robo y crackeo offline de tickets de servicio), AS-REP Roasting (usuarios sin preautenticación) y las bases de los ataques de tickets. El alumno ejecutará estos ataques en su AD lab y comprenderá por qué funcionan y cómo se detectan.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Explicar** el flujo Kerberos (AS-REQ/REP, TGS-REQ/REP) y dónde falla.
- 2. **Ejecutar** Kerberoasting y crackear el hash offline en el lab.
- 3. **Realizar** AS-REP Roasting contra cuentas sin preautenticación.
- 4. **Relacionar** cada ataque con su ID ATT&CK y su detección.
- 5. **Recomendar** mitigaciones (contraseñas fuertes de servicio, gMSA, monitoreo).

Temas

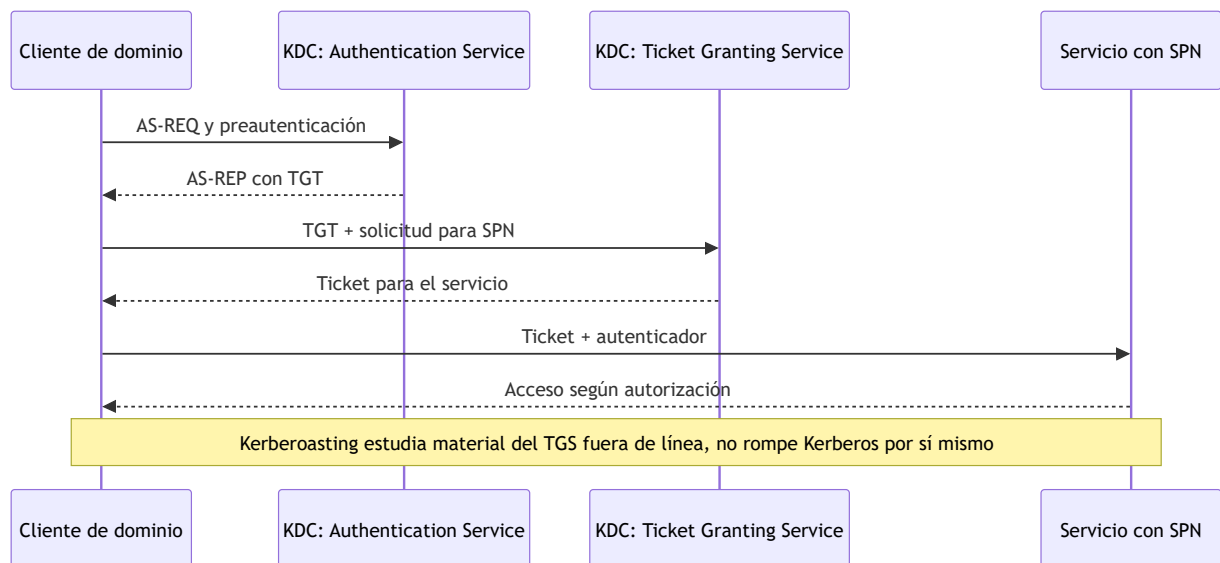
#	Tema	Por qué importa
1	Flujo Kerberos	Base para entender los ataques
2	TGT vs TGS	Distintos tickets, distintos abusos
3	Kerberoasting (T1558.003)	Crackeo offline de cuentas de servicio
4	AS-REP Roasting (T1558.004)	La ausencia de preautenticación expone material verificable fuera de línea
5	Tipos de cifrado (RC4 vs AES)	RC4 facilita el crackeo
6	Crackeo offline	Hashcat sobre los tickets
7	Detección y mitigación	Cómo lo ve y frena el Blue Team

Explicación en profundidad

Kerberos separa identidad de acceso a servicios

En un dominio, el **Key Distribution Center (KDC)** se ejecuta en los controladores de dominio y ofrece dos funciones lógicas: el Authentication Service y el Ticket Granting Service. Tras una autenticación válida, el cliente obtiene un TGT; después lo presenta para solicitar un ticket destinado a un SPN concreto. De esta forma, la contraseña del usuario no se envía a cada servicio.

Un ticket contiene información para el cliente y una parte protegida con una clave que el servicio correspondiente puede validar. El TGT está protegido con claves de `krbtgt`; el ticket de servicio incluye material protegido con la clave de la cuenta asociada al SPN. Esto explica por qué la calidad de la contraseña de una cuenta de servicio importa: un TGS capturado puede someterse a verificación de candidatos **fuera del dominio**, sin generar un inicio de sesión por cada candidato.



Qué condición hace posible Kerberoasting

Solicitar tickets para servicios es una operación normal. El riesgo aparece cuando el SPN está ligado a una cuenta con contraseña débil, reutilizada o muy antigua. ATT&CK clasifica esta actividad como `T1558.003`: se obtiene un TGS y se prueban candidatos contra su parte cifrada. No hace falta que el servicio acepte finalmente una conexión para iniciar esa comprobación fuera de línea.

El tipo de cifrado afecta al coste, pero no es una garantía aislada. RC4 utiliza material derivado del hash NT y facilita cracking muy optimizado; AES incorpora claves derivadas con sal. Aun así, una contraseña predecible sigue siendo una debilidad. La defensa preferente es usar cuentas administradas —como gMSA cuando corresponda—, contraseñas largas y aleatorias, mínimo privilegio y retirar RC4 donde la compatibilidad lo permita.

AS-REP Roasting es una condición diferente

La preautenticación obliga al cliente a demostrar conocimiento de su clave antes de que el KDC entregue una respuesta aprovechable. Si una cuenta tiene deshabilitado ese requisito, puede solicitarse un AS-REP con material verificable fuera de línea. Esto es `T1558.004`, no Kerberoasting. Separar ambas técnicas dirige la remediación: una exige revisar cuentas con SPN y sus claves; la otra, localizar la bandera que desactiva preautenticación salvo excepciones justificadas.

Leer los eventos como una secuencia

El evento 4768 registra solicitudes de TGT y el 4769 solicitudes de tickets de servicio cuando la auditoría correspondiente está habilitada. Un único 4769 no prueba abuso: es parte normal de Kerberos. La detección gana contexto al observar una cuenta que solicita numerosos SPN poco habituales, tipos de cifrado heredados, concentración temporal y desviación de su línea base. El ejercicio debe correlacionar identidad, endpoint y servicio, y evitar afirmar compromiso solo por volumen.

Definiciones y características

- **TGT (Ticket Granting Ticket):** ticket inicial que prueba la identidad. Característica: cifrado con la clave de `krbtgt`.
- **TGS (ticket de servicio):** ticket para un servicio concreto. Característica: una parte se protege con una clave de la cuenta de servicio; su derivación depende del tipo de cifrado.
- **Kerberoasting:** pedir TGS de cuentas con SPN y crackear offline su contraseña. Característica: no requiere privilegios, solo una cuenta de dominio.
- **AS-REP Roasting:** para usuarios con "no preauth", el AS-REP contiene material crackeable. Característica: ni siquiera hace falta conocer una contraseña.
- **Preautenticación:** paso que evita ataques al AS-REQ. Característica: deshabilitarla abre AS-REP Roasting.
- **RC4 (etype 23):** cifrado débil aún soportado. Característica: acelera enormemente el crackeo frente a AES.

Glosario

- **KDC:** servicio de distribución de claves que emite tickets Kerberos en el dominio.
- **Authentication Service:** función del KDC que procesa la autenticación inicial y emite el TGT.
- **Ticket Granting Service:** función del KDC que emite tickets para servicios concretos.
- **TGT:** ticket reutilizable para solicitar otros tickets durante su vigencia.
- **Ticket de servicio:** credencial Kerberos presentada a una instancia identificada por un SPN.
- **SPN:** nombre que vincula una instancia de servicio con su cuenta de inicio de sesión.
- **Preautenticación:** prueba previa de posesión de clave incluida en el intercambio inicial.
- **Kerberoasting:** obtención de TGS para comprobar candidatos de contraseña fuera de línea.
- **AS-REP Roasting:** comprobación fuera de línea posibilitada cuando una cuenta no exige preautenticación.
- **Etype:** identificador del tipo de cifrado negociado en Kerberos.
- **gMSA:** cuenta de servicio administrada por el dominio con gestión automática de contraseña.

Herramientas y preparación

- El AD lab / GOAD de la clase anterior, con al menos una cuenta de servicio con SPN y contraseña débil.
- **Impacket:** `GetUserSPNs.py`, `GetNPUsers.py`.
- **Rubeus** (desde Windows) como alternativa nativa.
- **Hashcat** con diccionarios (rockyou) para el crackeo offline.

 Ejecuta estos ataques solo en tu AD lab / GOAD. El crackeo offline no toca el DC más de lo normal, pero solicitar muchos TGS es telemetría; hazlo comprendiendo la detección. Nunca contra dominios

ajenos sin autorización.

Laboratorio guiado

1. **Repaso del flujo.** Dibuja AS-REQ → AS-REP (TGT) → TGS-REQ → TGS-REP y marca dónde entra material crackeable.
2. **Kerberoasting con Impacket:**

```
bash GetUserSPNs.py lab.local/lowuser:Passw0rd -dc-ip 10.10.10.10 -request -outputfile roast.txt
```

3. **Crackea offline:**

```
bash hashcat -m 13100 roast.txt /usr/share/wordlists/rockyou.txt
```

Recupera la contraseña de la cuenta de servicio. 4. **AS-REP Roasting:**

```
bash GetNPUsers.py lab.local/ -usersfile users.txt -dc-ip 10.10.10.10 -no-pass -format hashcat hashcat -m 18200 asrep.txt rockyou.txt
```

5. **Con Rubeus (Windows):** `Rubeus.exe kerberoast /outfile:roast.txt` y compara el flujo con Impacket.
6. **Fuerza RC4 y compara.** Solicita el TGS con etype RC4 y observa cuánto más rápido crackear frente a AES.
7. **Detección.** Revisa en el DC los eventos `4769` (TGS solicitado) con etype 0x17 (RC4) y documenta cómo el Blue Team los usa para alertar.

Ejercicios

1. Describe el flujo Kerberos y explica por qué el TGS es crackeable.
2. Ejecuta Kerberoasting y crackea al menos una cuenta del lab.
3. Encuentra una cuenta sin preautenticación y haz AS-REP Roasting.
4. Compara tiempos de crackeo RC4 vs AES para el mismo hash.
5. Explica cómo gMSA mitiga el Kerberoasting.
6. Escribe la regla de detección basada en el evento 4769 con RC4.

Reto verificable

Compromete la contraseña de una **cuenta de servicio** de tu AD lab mediante Kerberoasting y crackeo offline, y documenta el evento que el DC generó. **Criterio de aceptación:** obtienes en claro la contraseña de una cuenta con SPN, muestras el comando de solicitud y el de crackeo, e identificas el evento `4769` con etype RC4 correspondiente en el registro del DC.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No devuelve hashes	No hay cuentas con SPN o credenciales inválidas; revisa enumeración (Clase 170)
Hashcat no cracker	Contraseña fuerte o modo incorrecto; verifica <code>-m 13100/18200</code> y el diccionario
AS-REP Roasting vacío	Ninguna cuenta con "no preauth"; configúrala en el lab para practicar
Solo hashes AES	Servicio con AES; el crackeo es más lento, usa mejor diccionario/reglas
Detectado al instante	Muchas solicitudes RC4; el SOC alerta por eventos 4769 anómalos

Preguntas frecuentes

 **¿Kerberoasting necesita privilegios?** No. Cualquier cuenta de dominio puede solicitar TGS de servicios con SPN. Por eso es tan popular: bajo requisito, alto impacto si hay contraseñas débiles.

 **¿Por qué importa retirar RC4?** El material RC4 permite comprobaciones de candidatos mucho más económicas que los tipos AES habituales. Su retirada debe planificarse con inventario de compatibilidad, y siempre se combina con claves de servicio fuertes y cuentas administradas.

 **¿Cómo se previene?** Contraseñas largas y aleatorias para cuentas de servicio, uso de gMSA/dMSA, deshabilitar RC4 y monitorizar solicitudes de TGS anómalas.

Referencias

- Microsoft — *Kerberos authentication overview*. <https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview> — fuente principal para el papel del KDC, TGT, tickets de servicio y AD DS.
- Microsoft — *Mutual Authentication Using Kerberos*. <https://learn.microsoft.com/en-us/windows/win32/ad/mutual-authentication-using-kerberos> — sustenta la relación entre SPN, cuenta de servicio y autenticación.
- MITRE ATT&CK — *Kerberoasting* (T1558.003). <https://attack.mitre.org/techniques/T1558/003/> — condiciones, fuentes de detección y mitigaciones de la técnica.
- MITRE ATT&CK — *AS-REP Roasting* (T1558.004). <https://attack.mitre.org/techniques/T1558/004/> — referencia para no confundir la ausencia de preautenticación con Kerberoasting.
- Rubeus. <https://github.com/GhostPack/Rubeus> y Hashcat — *example hashes*. https://hashcat.net/wiki/doku.php?id=example_hashes — documentación de las herramientas del laboratorio; no sustituyen la especificación de Kerberos.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 170 — Active Directory: enumeración](#)

Siguiente clase

[Clase 172 — Active Directory: Pass-the-Hash y Pass-the-Ticket](#)